



Enterprise SOC

SOC / NOC Central de Grupo Bistro

Manual de instalación, operación y seguridad

NOC/SOC de monitoreo de infraestructura Windows y de red: telemetría, backups, Fortinet, acceso remoto, asistente con IA, alertas y auditoría

Versión del documento: 24/09/2026

Autor: Francisco E. Lahoz F.

Uso interno — contiene procedimientos de despliegue y notas de seguridad

Índice

1. Qué es Enterprise SOC
2. Arquitectura del sistema
3. Instalación del NOC/SOC central (VPS Linux)
4. Instalación del agente en cada servidor cliente
5. Seguridad: qué cubre y qué no
6. Operación diaria
7. Problemas conocidos y cómo se resolvieron
8. Checklist final antes de anunciar la URL
9. Referencia rápida de comandos

1. Qué es Enterprise SOC

Enterprise SOC es un sistema propio de monitoreo tipo NOC/SOC para infraestructura Windows (Windows Server y Windows 10/11). Un componente central (backend + dashboard web) recibe datos de agentes livianos instalados en cada servidor a monitorear, y muestra el estado de todos ellos en tiempo real, con generación automática de alertas.

Componentes

- **Backend** (Node.js + Express + PostgreSQL): recibe telemetría, estado de backup y eventos Fortinet vía API, evalúa umbrales, genera alertas, las distribuye en vivo por WebSocket, y arma el túnel de acceso remoto y las respuestas del asistente con IA.
- **Frontend** (Next.js): dashboard con pestañas General, Monitoreo, Topología, Logs, Fortinet y Admin (usuarios, servidores, dispositivos Fortinet, configuración editable y auditoría), más un asistente flotante y un botón de acceso remoto por servidor.
- **Agente** (Python, compilado a .exe): corre en cada servidor Windows, reporta CPU/RAM/disco, errores del Visor de Eventos, estado de backup (Windows Server Backup / wbadmin / VSS), se auto-actualiza cuando el backend publica una versión nueva, y mantiene un canal de control para el acceso remoto.

Qué NO es

No es un producto comercial con soporte externo, no tiene certificaciones de seguridad (SOC 2, ISO 27001, etc.), y no fue auditado por un tercero independiente. Es una herramienta construida a medida — la sección 5 detalla honestamente qué protecciones tiene y cuáles le faltan.

2. Arquitectura del sistema

Central (un VPS por cliente/organización):

- PostgreSQL (datos: usuarios, servidores, telemetría, backups, alertas, auditoría)
- Backend API + WebSocket (puerto interno 3000, solo accesible vía Nginx)
- Frontend / dashboard (puerto interno 3001, solo accesible vía Nginx)
- Nginx como reverse proxy con TLS (Let's Encrypt / Certbot)

En cada servidor a monitorear:

- Agente Windows (.exe), corre como tarea programada con privilegios SYSTEM
- Se comunica solo de forma saliente (outbound HTTPS) hacia el backend central — no escucha ningún puerto entrante, no requiere abrir el firewall del servidor monitoreado

ATENCIÓN: Este sistema no es multi-tenant: cada organización/cliente necesita su propio VPS y su propio backend. No hay aislamiento de datos entre distintos clientes dentro de un mismo backend.

3. Instalación del NOC/SOC central (VPS Linux)

El stack central corre completo con Docker Compose (PostgreSQL + backend + frontend). El VPS no necesita Node.js instalado — todo se construye dentro de los contenedores. Nginx corre en el host como reverse proxy con TLS.

3.1 Provisionar el VPS (una sola vez)

```
scp deploy/setup-server.sh root@TU_IP:/root/  
ssh root@TU_IP  
sudo bash /root/setup-server.sh
```

Instala Docker, Nginx, Certbot, crea el usuario socapp sin privilegios, y configura el firewall (ufw) para que solo los puertos 22 (SSH) y 80/443 (Nginx) queden expuestos.

3.2 Subir el código

```
su - socapp  
git clone <url-de-tu-repo-privado> enterprise-soc  
cd enterprise-soc
```

El repositorio se desarrolló localmente con git pero sin remoto configurado — hay que subirlo a un repositorio privado (GitHub/GitLab) o transferir la carpeta por rsync/scp.

3.3 Configurar variables de producción

```
cp .env.example .env  
nano .env
```

Como mínimo, completar con valores nuevos de producción (nunca reutilizar los de desarrollo):

```
POSTGRES_USER=nocsoc_prod  
POSTGRES_PASSWORD=<openssl rand -hex 32>  
JWT_SECRET=<openssl rand -hex 32>  
AGENT_ENROLLMENT_SECRET=<openssl rand -hex 32>  
CORS_ORIGIN=https://noc.tudominio.com  
NEXT_PUBLIC_API_URL=https://noc.tudominio.com  
NEXT_PUBLIC_WS_URL=wss://noc.tudominio.com/ws
```

3.4 Build y arranque

```
docker compose build  
docker compose up -d  
docker compose ps # los 3 servicios deberian quedar "Up"
```

Las migraciones de base de datos se aplican solas al arrancar el backend (prisma migrate deploy, se ejecuta en cada arranque del contenedor y es seguro correrlo repetidas veces).

3.5 Crear el primer usuario administrador

```
docker exec enterprise-soc-backend node prisma/seed.js
```

Guardar el email/contraseña que imprime: no se pueden recuperar después, solo se guarda su hash.

3.6 Nginx + certificado TLS

```
sudo cp deploy/nginx.conf /etc/nginx/sites-available/enterprise-soc
sudo nano /etc/nginx/sites-available/enterprise-soc # reemplazar el dominio
sudo ln -s /etc/nginx/sites-available/enterprise-soc /etc/nginx/sites-enabled/
sudo nginx -t && sudo systemctl reload nginx
sudo certbot --nginx -d noc.tudominio.com
```

A partir de acá, <https://noc.tudominio.com> sirve el dashboard con certificado válido.

4. Instalación del agente en cada servidor cliente

ATENCIÓN: Requiere ejecutarse como Administrador en el servidor Windows. Es necesario para que la revisión de backups (wbadmin / WMI de Windows Server Backup) pueda leer el estado real.

4.1 Compilar el agente (una sola vez, en cualquier Windows con Python)

```
cd agent
pip install -r requirements.txt
pip install pyinstaller
pyinstaller --onefile --name enterprise-soc-agent ^
--hidden-import=win32timezone --hidden-import=win32api agent.py
```

4.2 Publicarlo en el backend para descarga automática

```
scp dist/enterprise-soc-agent.exe socapp@TU_IP:~/enterprise-soc/backend/downloads/
docker cp ~/enterprise-soc/backend/downloads/enterprise-soc-agent.exe \
enterprise-soc-backend:/app/downloads/
```

4.3 Instalar en cada servidor a monitorear

En el servidor Windows, en una PowerShell como Administrador, con el instalador (install-agent.ps1) copiado a la máquina:

```
.\install-agent.ps1 -BackendUrl "https://noc.tudominio.com" `
-EnrollmentSecret "<el AGENT_ENROLLMENT_SECRET del .env central>"
```

Con ese único comando, el instalador:

- Descarga el .exe del agente desde el backend (si no hay uno local ya compilado al lado del script)
- Se auto-registra en el NOC llamando a POST /api/servers/enroll con el secreto compartido — el servidor aparece solo en el dashboard, sin tocar la base de datos ni el panel a mano
- Registra una Tarea Programada de Windows que corre como SYSTEM, con reinicio automático si el proceso se cae, y la arranca de inmediato

Para desinstalar: .\uninstall-agent.ps1 (opcionalmente con -RemoveFiles para borrar también los archivos instalados).

5. Seguridad: qué cubre y qué no

Ningún sistema es 100% seguro. Esta sección es una evaluación honesta de la postura de seguridad actual, para decidir con criterio si hace falta reforzar algo antes de usarlo con datos reales de un cliente.

Cubierto

Área	Protección implementada
Contraseñas y API keys	Hasheadas con bcrypt (costo 12), nunca en texto plano en la base
Autenticación	Login con email+contraseña; sesión vía JWT firmado guardado en una cookie httpOnly
Segundo factor (2FA)	TOTP (Google Authenticator, Authy, etc.) opcional por usuario, con códigos de respaldo de un solo uso
Almacenamiento de sesión	Cookie httpOnly + Secure (en producción) + SameSite=Strict — nunca accesible desde JavaScript
Revocación de sesión	Cada sesión queda registrada en la base: se puede cerrar individualmente (logout), en todos los dispositivos
CSRF	SameSite=Strict como primera barrera, más un chequeo de origen (Origin) en toda escritura como POST
Autorización (RBAC)	Roles ADMIN/ANALYST/VIEWER aplicados con middleware en cada endpoint sensible
Transporte	TLS vía Nginx + Let's Encrypt (una vez desplegado según la sección 3.6)
Rate limiting	Por IP en login, 2FA, telemetría, backups, endpoints admin, y un límite general sobre toda la API
Validación de entrada	Zod con modo estricto: rechaza campos no declarados en cada payload
Red / firewall	Postgres y los puertos internos de la app nunca expuestos a internet (ufw + binding a 127.0.0.1)
Auditoría	Registro de logins, 2FA, altas/bajas de usuarios y servidores, cambios de umbrales, ack/resuelve de incidentes
Credenciales por servidor	Cada agente tiene su propia API key (no un secreto compartido) — una fuga solo compromete un agente
Dependencias	0 vulnerabilidades reportadas por npm audit en backend, frontend y la herramienta de acceso remoto
Configuración sensible	Contraseñas SMTP, webhooks, secretos y API keys guardados desde el panel nunca se devuelve en respuestas
Acceso remoto (RDP/VNC)	Solo ADMIN puede iniciarlo; token de sesión de un solo uso (bcrypt-hasheado, se invalida en el primer uso)
Ingesta Fortinet	Cada dispositivo tiene su propia API key (igual que los agentes); el receptor de syslog descarta paquetes no esperados
Asistente (Claude)	El contexto que se le pasa está delimitado explícitamente como datos (no instrucciones), como de cualquier otro agente

NO cubierto (limitaciones conocidas)

Área	Limitación
Auditoría externa	El código no fue revisado por nadie ajeno a este desarrollo, ni sometido a un pentest formal — ningún agente
Multi-tenancy	Un backend = una organización, por diseño. Para Grupo Bistro como cliente único de este backend
Prueba de backup en Windows Server	Se revisó WMI (MSFT_WBSummary, Windows Server Backup) se revisó y se reforzaron sus logs

Área	Limitación
Recuperación de contraseña	No hay flujo de "olvidé mi contraseña" por email; solo un ADMIN puede recrear la cuenta
Parseo de syslog Fortinet	Escrito según el formato estándar de FortiOS documentado públicamente, pero no probado contra
Puerto UDP de syslog Fortinet	Si se activa, es el único puerto de todo el sistema que necesita quedar accesible desde afuera del

6. Operación diaria

6.1 Usuarios y servidores (pestaña Admin, solo rol ADMIN)

- **Nuevo usuario:** pestaña Admin → formulario "+ Nuevo usuario" (nombre, email, contraseña, rol).
- **Eliminar usuario:** botón Eliminar en su fila. No se puede eliminar la propia cuenta ni al último administrador restante.
- **Nuevo servidor (manual):** formulario "+ Nuevo servidor" — muestra el SERVER_ID y API_KEY una única vez, copiarlos al .env del agente.
- **Nuevo servidor (automático):** usar el instalador del agente con AGENT_ENROLLMENT_SECRET (sección 4.3) — no requiere pasar por el dashboard.
- **Rotar API key:** invalida la clave actual de inmediato y genera una nueva (útil si se sospecha que se filtró).

6.2 Umbrales por servidor

En Admin → Servidores → "Configurar": permite fijar umbrales de advertencia/crítico de CPU, RAM y disco distintos para cada servidor. Vacío = usar el default global (CPU 75/90%, RAM 80/90%, Disco 85/95%).

6.3 Ventanas de mantenimiento

Desde el mismo panel, botones de 1h/4h/24h (o "Terminar ahora"). Mientras está activa, la telemetría y el estado de backup se siguen guardando normalmente, pero no generan alertas — útil para actualizaciones planeadas sin ruido de falsas alarmas.

6.4 Notificaciones externas

En el .env central (sección 3.3), completar cualquiera de estos antes de levantar el stack:

- **Email:** SMTP_HOST, SMTP_PORT, SMTP_USER, SMTP_PASS, SMTP_FROM, ALERT_EMAIL_TO
- **Slack:** SLACK_WEBHOOK_URL (Incoming Webhook)
- **Webhook genérico:** WEBHOOK_URL (Teams, Discord, PagerDuty, sistema propio)

Solo se notifican alertas HIGH o CRITICAL (ajustable con NOTIFY_MIN_SEVERITY).

6.5 Reconocer y resolver alertas

Pestaña Logs Regex: cada alerta abierta tiene botones "Reconocer" y "Resolver". Queda registrado quién y cuándo en la auditoría (Admin → Auditoría).

6.6 Segundo factor (2FA) y sesiones

Botón "Mi cuenta" (arriba a la derecha, en cualquier pantalla): cada usuario activa su propio 2FA escaneando un código QR con Google Authenticator, Authy o similar. Al confirmarlo se muestran 8 códigos de respaldo de un solo uso — guardarlos ahí mismo, no se vuelven a mostrar. A partir de ese momento, cada login pide el código además de la contraseña.

- **Perdiste el dispositivo del 2FA:** un ADMIN lo restablece desde Admin → Usuarios → "Restablecer 2FA" (lo desactiva y cierra las sesiones activas de esa cuenta).
- **Cerrar tu propia sesión en todos lados:** Mi cuenta → "Cerrar sesión en todos los dispositivos".
- **Forzar el cierre de sesión de otro usuario:** Admin → Usuarios → "Cerrar sesiones" (cuenta comprometida, baja de un empleado, etc.). Tiene efecto inmediato: a diferencia de un JWT clásico, la sesión queda invalidada en el momento, no cuando expira.

6.7 Deploys y rollback

```
./deploy/deploy.sh # actualiza a lo ultimo de la rama actual
./deploy/deploy.sh v1.2.0 # o a un commit/tag especifico
./deploy/rollback.sh <commit-anterior> # revierte el codigo (no las migraciones de BD)
```

6.8 Configuración editable desde el panel

Admin → Configuración centraliza casi todo lo que antes solo se podía tocar editando el .env y reiniciando: notificaciones, umbrales globales por defecto, duración de sesión, secreto de auto-enrolamiento, versión publicada del agente, Fortinet y la API key del asistente. Un valor guardado ahí tiene prioridad sobre la variable de entorno y aplica en caliente (hasta 10 segundos de caché interno), con una sola excepción: el receptor de syslog de Fortinet abre un socket al arrancar el proceso, así que activarlo requiere reiniciar el backend.

6.9 Etiquetas de servidores

Admin → Servidores → "Configurar" permite asignarle etiquetas libres a cada servidor (sucursal, ambiente, rol, etc.), separadas por coma. Solo son organizativas, no afectan alertas ni permisos.

6.10 Monitor Fortinet

Pestaña Fortinet, alimentada por dispositivos dados de alta en Admin → Fortinet. Dos formas de ingesta, configurables por dispositivo:

- **Por API (recomendado):** un script propio, corriendo en la misma red que el FortiGate, hace polling contra su API y reenvía eventos con POST /api/forti/events (headers X-Device-Id y X-API-Key, igual que un agente Windows).
- **Syslog UDP:** activar el receptor en Admin → Configuración → Fortinet (requiere reiniciar el backend) y apuntar el FortiGate a la IP del VPS. Solo procesa paquetes de IPs registradas como dispositivo. **Este es el único puerto de todo el sistema que necesita exponerse fuera del VPS** — y Docker ignora ufw para los puertos que publica explícitamente, así que hay que restringir el origen (IP del FortiGate o una VPN) antes de descomentar ese puerto en docker-compose.yml.

Eventos de ataques bloqueados (IPS), virus, failover de HA e interfaces caídas, o cualquiera marcado CRITICAL, disparan notificación por los mismos canales de la sección 6.4.

6.11 Acceso remoto (RDP/VNC) sin abrir puertos

Admin → Servidores → "Conectar" (visible solo si se activó en Admin → Configuración → Acceso remoto) arma un túnel inverso: el agente ya instalado se conecta hacia el backend cuando se le pide, sin necesidad de abrir ningún puerto entrante en el servidor ni tocarlo a mano.

```
cd tools && npm install # en tu propia maquina, una sola vez
node remote-relay.js --backend wss://noc.tudominio.com \
--session <id> --token <token> # datos que da el boton "Conectar"
mstsc /v:localhost:13389 # o tu cliente VNC
```

- Token de un solo uso (una segunda conexión con el mismo token se rechaza) y expira a los 2 minutos si no se usa; el túnel completo se corta solo a los 30 minutos como máximo.
- El backend nunca interpreta el contenido del túnel — es un relay de bytes puro. La autenticación de la sesión RDP/VNC en sí la sigue haciendo Windows.
- Solo ADMIN puede iniciarlo, y queda registrado en Auditoría quién, cuándo y sobre qué servidor.

6.12 Asistente (Claude)

Botón flotante ■, disponible para cualquier usuario logueado. Requiere una API key de console.anthropic.com cargada en Admin → Configuración → Asistente — es un producto distinto y de facturación separada de una suscripción Claude Pro de claude.ai, que no sirve para esto. Cada consulta se manda con un resumen en vivo de alertas abiertas, servidores y eventos Fortinet recientes, para que pueda responder sobre el estado real sin copiar y pegar nada.

6.13 Actualización automática de agentes

Al publicar un .exe nuevo del agente (sección 4.2), completar Admin → Configuración → Sesión y agentes → "Última versión de agente publicada" con el mismo número que tiene AGENT_VERSION en agent/agent.py. En su próximo ciclo, cada agente con una versión anterior se descarga el .exe nuevo, se reemplaza a sí mismo, y se reinicia solo — no hace falta volver a correr install-agent.ps1 en cada servidor.

7. Problemas conocidos y cómo se resolvieron

Bugs reales encontrados durante el desarrollo y las pruebas — documentados por si vuelven a aparecer.

Síntoma	Causa y solución
Acentos corruptos en el detalle de Backlog (ding de ah)	Fallo de <code>encoding</code> de la consola de Windows no era fijo (mbcs ni el codepage OEM). Se resolvió con <code>setlocale(LC_ALL, 'C')</code> .
"Could not parse schema engine response" en el Primer motor de Stack Overflow	Se usó <code>node:20-alpine</code> en SSL; la imagen <code>node:20-alpine</code> no lo trae por defecto. Se agregó <code>apk add openssl</code> .
Scripts <code>.sh</code> fallan en el VPS Linux con saltos de línea CRLF (de Windows) en vez de LF.	Se añadieron <code>gitattributes</code> con <code>text=auto</code> y se corrigieron los saltos de línea.
Dashboard vacío al abrir una pestaña de WebSockets	El WebSocket no recibe eventos nuevos desde que se conecta; no había carga del estado ya que se usaba <code>localStorage</code> .
Build de Next.js falla con "specified property does not exist"	Se usaba <code>next.config.js</code> con valores por defecto antes de un spread del mismo tipo — <code>next dev</code> no los soporta.
WebSocket se cae al leer la cookie de sesión	La cookie <code>session</code> se usaba como <code>session</code> en la versión 2.0.0. Se cambió a <code>session_id</code> y se agregó <code>HttpOnly</code> .
Falla la generación de códigos 2FA	El <code>otpauth</code> no se importaba correctamente. Se cambió a <code>otpauth</code> y se agregó <code>otpauth</code> .
El canal de control de agentes y el túnel de acceso remoto se caen	Una librería de <code>abort-controller</code> no se importaba correctamente. Se cambió a <code>abort-controller</code> .
El túnel de acceso remoto se cuelga	El <code>WebSocket</code> no se cerraba correctamente. Se agregó <code>close</code> y se agregó <code>close</code> .
El túnel de acceso remoto pierde los datos	Se usaba <code>localStorage</code> para guardar los datos. Se cambió a <code>localStorage</code> y se agregó <code>localStorage</code> .

8. Checklist final antes de anunciar la URL

- ☐ CORS_ORIGIN, NEXT_PUBLIC_API_URL y NEXT_PUBLIC_WS_URL apuntan al dominio real del cliente
- ☐ POSTGRES_PASSWORD, JWT_SECRET y AGENT_ENROLLMENT_SECRET son nuevos, generados para esta instalación (no reutilizados)
- ☐ NODE_ENV=production en el backend (ya viene fijo en docker-compose.yml) — de esto depende que la cookie de sesión salga marcada Secure
- ☐ Postgres y los puertos 3000/3001 no responden desde fuera del VPS (ufw status, y los puertos ligados a 127.0.0.1 en docker compose ps)
- ☐ TLS activo: candado verde en el navegador, wss:// (no ws://) en la consola
- ☐ Contraseña del usuario ADMIN inicial guardada en un lugar seguro (gestor de contraseñas, no en texto plano)
- ☐ 2FA activado en la cuenta ADMIN inicial, con los códigos de respaldo guardados en un lugar seguro
- ☐ Al menos un canal de notificación externa configurado (email, Slack o webhook) para alertas CRITICAL
- ☐ Estado de backup verificado con python agent.py --debug --once en al menos un servidor Windows real (sección 5, limitación conocida)
- ☐ Cliente/organización informado de las limitaciones de seguridad de la sección 5 (sin pentest externo, sin recuperación de contraseña por email)
- ☐ Si vas a usar el receptor de syslog de Fortinet, revisaste la nota de ufw vs. Docker (sección 6.10) antes de exponer el puerto UDP
- ☐ Si vas a usar el acceso remoto (sección 6.11), el equipo entiende que es la función de mayor privilegio del sistema y quién puede usarla (solo ADMIN)

9. Referencia rápida de comandos

Acción	Comando
Ver estado de los contenedores	<code>docker compose ps</code>
Ver logs del backend	<code>docker logs enterprise-soc-backend -f</code>
Ver logs del frontend	<code>docker logs enterprise-soc-frontend -f</code>
Reiniciar todo	<code>docker compose restart</code>
Crear un usuario/servidor de prueba	<code>docker exec enterprise-soc-backend node prisma/seed.js</code>
Backup manual de la base	<code>docker exec enterprise-soc-postgres pg_dump -U <user> nocsoc > backup.sql</code>
Deploy de una versión nueva	<code>./deploy/deploy.sh</code>
Rollback	<code>./deploy/rollback.sh <commit></code>
Instalar el agente en un servidor	<code>.\install-agent.ps1 -BackendUrl ... -EnrollmentSecret ...</code>
Desinstalar el agente	<code>.\uninstall-agent.ps1</code>
Probar el agente en modo debug (sin instalar)	<code>python agent.py --debug --once</code>
Ver la versión del agente instalado	<code>python agent.py --version</code>
Conectar por acceso remoto (en tu máquina)	<code>node tools/remote-relay.js --backend wss://... --session <id> --token <token></code>
Mandar un evento Fortinet de prueba	<code>curl -X POST https://.../api/forti/events -H "X-Device-Id: ..." -H "X-API-Key: ..." -d '{...}'</code>

Documento generado como parte del desarrollo de Enterprise SOC. Autor: Francisco E. Lahoz F. Mantenerlo actualizado a medida que el sistema evolucione.